

SWIFT RECOVERY

A Multi-Vector Cyber Attack Against GlobalTrust Bank

INCIDENT DATE	DURATION	ATTACK EVENTS	March 15, 2024	3
	hours	15,500		
UNIQUE ATTACKERS	COUNTRIES	FINANCIAL IMPACT	550 IPs	13
		\$890,000		

Prepared by the Security Operations Center

CONFIDENTIAL

CONFIDENTIAL

Operation Swift Recovery — Cyber Incident Analysis GlobalTrust Bank

Contents

- 1 Executive Summary
- 2 Company Background
- 3 The Attack — What Happened
- 4 Business Impact

5 The Data Available

6 Stakeholder Requirements

7 Analysis Questions

8 Evaluation Criteria

9 Background Reading

10 Glossary

CONFIDENTIAL Operation Swift Recovery Page 2
Operation Swift Recovery — Cyber Incident Analysis GlobalTrust Bank

Section 1 | Executive Summary

On March 15, 2024, GlobalTrust Bank experienced a coordinated, multi-vector cyber attack that lasted approximately three hours during overnight hours. The campaign combined volumetric denial-of-service traffic with application-layer attacks against the bank's authentication and data-tier infrastructure. While core defensive controls held — multi-factor authentication prevented every attempted credential compromise, and no customer data exfiltration has been confirmed — the incident exposed material weaknesses in web application defenses and overnight response capacity that demand attention.

The attack was sophisticated in coordination but modest in scale relative to large-bank incidents: 550 unique

attacker IPs across 13 countries generated 15,500 logged attack events. Roughly 340,000 customers were affected during the outage window, with a directly attributable financial impact of approximately \$890,000.

Incident at a Glance

Attack window	March 15, 2024 — 02:00 to 05:00 UTC
Duration	Approximately 3 hours
Attack vectors observed	5 (DDoS SYN flood, DDoS UDP flood, SQL injection, brute force, XSS)
Attack events logged	15,500
Unique attacking IPs	550
Source countries	13
Internal services targeted	10
Customers impacted	Approximately 340,000
Overall block rate	88.4%
Successful (unblocked) events	1,794 (11.6%)
Confirmed data exfiltration	None at time of report
Estimated financial impact	\$890,000 (direct costs)

Why This Matters

Three findings deserve immediate attention from leadership. First, although the bank's perimeter and identity controls performed well in aggregate, SQL injection had a notably lower block rate than other vectors — a gap concentrated at the web-application layer rather than at the network edge. Second, the timing of the attack was deliberately selected to minimize defensive response: the campaign launched within seconds across all five vectors at 02:00 UTC, when overnight SOC staffing was at its lowest. Third, while the geographic distribution of

flagged as APT-suspected by external threat intelligence — concentrate in a small set of jurisdictions and infrastructure providers.

These observations together point to a planned, professional operation rather than opportunistic scanning. The investment recommendations in Section 4 are scoped to address the specific gaps this incident exposed.

Section 2 | Company Background

GlobalTrust Bank Profile

GlobalTrust Bank is a mid-sized regional financial institution headquartered in Chicago, Illinois, with operations across 12 states in the Midwest and Eastern United States. Founded in 1987 as a community savings institution, the bank has grown into a full-service financial services provider with \$47 billion in assets under management.

Founded	1987
Headquarters	Chicago, Illinois
Total assets	\$47 billion
Employees	8,200
Retail branches	312
Customer accounts	4.2 million
Annual revenue	\$3.1 billion
Stock ticker	GTB (NYSE)

Digital Services Portfolio

Roughly 67% of customer transactions flow through digital channels. The platforms most directly affected by the incident are the customer-facing portal, the mobile API gateway, and the authentication and core-banking back ends that sit behind them.

Online Banking Portal	2.8 M	1.2 M	34%
Mobile Banking App	1.9 M	890 K	28%
Business Banking Platform	124 K	340 K	22%
Wire Transfer System	45 K	12 K	8%
Investment Portal	280 K	45 K	5%

API Banking Services	1.2 K	2.1 M	3%

Technology Estate

GlobalTrust runs a hybrid estate combining on-premises data centers in Chicago and Columbus (N+1 redundancy) with cloud workloads on AWS for customer-facing services and Azure as a secondary provider. A Cloudflare CDN provides basic-tier DDoS mitigation. Legacy COBOL mainframe systems still handle core banking ledger operations, while newer digital services are deployed as microservices on Kubernetes. Perimeter security combines Cisco Firepower and Palo Alto firewalls.

The Security Operations Center is staffed by 23 full-time analysts on a 24/7 rota. In the months before the incident the team had been operating with persistent vacancies on the overnight shift — a fact that became material once the attack timing is considered.

Section 3 | The Attack — What Happened

Timeline of Events

The campaign unfolded over roughly three hours starting at 02:00 UTC (21:00 US Eastern, 20:00 Central). Within the first 30 seconds, all five attack vectors were active. The compressed launch and the deliberate choice of overnight hours are both signatures of a professional, pre-planned operation. The reconstructed timeline below combines automated telemetry with annotations from the incident response team.

02:00:04	First brute-force attempt logged against authentication tier	Medium
02:00:32	All five attack vectors active (full multi-vector launch)	High
02:05	SIEM correlation flags SYN-flood pattern against load balancer	High
02:08	SOC analyst escalates to incident response (Sev 2)	High
02:15	Coordinated DDoS confirmed; over 500 unique source IPs	High
02:20	Geographic clustering identified; threat intel flagged	Critical
02:30	Geo-blocking and rate-limiting rules activated	High
02:35	DDoS volume escalates; ISP scrubbing engaged	Critical
02:58	Peak attack intensity (178 events/minute)	Critical
03:00	SQL injection pattern detected in volume; WAF rules updated	Critical
03:30	Sustained pressure on Core Banking Database tier	Critical
03:35	Anomalous query flagged on Core Banking Database; forensic capture started	Critical
03:40	External database connections temporarily blocked; read-only mode	High
04:00	DDoS volume begins measurable decline	Medium
04:15	Initial WAF rule gaps identified; updates queued	High
04:35	Brute-force and SQL injection attempts taper off	Medium
04:55	All attack vectors at baseline; incident moves to post-mortem phase	Low
06:30	All services restored; investigation continues	Info

Attack Vector Analysis

The campaign deployed five distinct techniques. Two — SYN flood and UDP flood — are volumetric DDoS variants designed to exhaust network and bandwidth resources. The other three target the application layer and aim at credential or data compromise. The block rates and event counts below are taken directly from SIEM logs.

DDoS SYN flood	5,048	32.6%	92.0%	406
DDoS UDP flood	4,279	27.6%	90.8%	392
SQL injection	3,164	20.4%	75.8%	767
Brute force	1,639	10.6%	91.5%	140
XSS attempt	1,370	8.8%	93.5%	89
TOTAL	15,500	100.0%	88.4%	1,794

1. DDoS — Volumetric Attacks (SYN Flood + UDP Flood)

Distributed denial-of-service attacks aim to exhaust a target's capacity by saturating bandwidth, connection tables, or compute resources. The bank saw two volumetric variants in parallel: SYN flood, which abuses the TCP three-way handshake by sending half-open connections, and UDP flood, which sends large volumes of stateless UDP packets — typically with amplification techniques (NTP, memcached, SSDP, DNS) to multiply traffic. Together the two DDoS vectors represented just over 60% of all logged events and were largely absorbed by the perimeter. The bank's basic-tier mitigation held, but only narrowly: the peak rate exceeded the headroom of the existing service tier and would not have survived a longer or larger campaign.

2. SQL Injection — The Highest-Impact Vector

SQL injection exploits applications that incorporate user input directly into database queries. The bank logged 3,164 SQL injection attempts, of which 767 (24%) were not blocked by perimeter or WAF controls. Forensic review of those 767 events found that none successfully extracted customer records; the database tier's parameterized-query layer and stored-procedure boundary stopped the actual data access. However, the proportion that reached the application layer is high relative to the other vectors and represents the incident's most material defensive gap. Observed techniques included UNION-based, blind (boolean and time-based), error-based, and out-of-band injection patterns.

Why the gap matters: the WAF's signature-based rules blocked the broad majority of obvious payloads. The 24% that reached the application were primarily blind and time-based techniques whose syntactic footprint is harder to match with static rules. This is the single highest-leverage area for security improvement (see Section 4).

3. Brute Force — Targeted at Authentication Surfaces

Brute-force traffic peaked at roughly 70 attempts per minute concentrated against the bank's authentication tier and database management endpoints. The credential lists used appear consistent with leaked corpora from prior third-party breaches (credential stuffing). Twelve employee accounts were temporarily locked out by progressive lockout policy. Multi-factor authentication blocked 100% of attempts that produced a valid password match — no unauthorized authentication was completed. The attack's notable feature is its targeting: the brute-force traffic concentrated on the same internal IPs as the SQL injection campaign, indicating the attackers had prior knowledge of the bank's service topology.

4. XSS Attempts — Lower Volume, Lower Risk

Cross-site scripting attempts (1,370 events) targeted reflected, stored, and DOM-based injection points. The block rate was the highest of any vector at 93.5%. The 89 attempts that reached the application layer did not

result in script execution in any session examined during forensic review.

Coordination Indicators

Several patterns in the data indicate this was a single, coordinated operation rather than separate opportunistic actors. The strongest of these is the launch synchronization: the first event of every attack type appeared within a 27.8-second window starting at 02:00:04 UTC. A second indicator is multi-vector capability per source IP — 412 of the 550 attacking IPs (75%) participated in all five attack types, and 536 (97%) participated in four or more. A third indicator is the small infrastructure footprint: 550 IPs generating sustained pressure across all five vectors implies access to high-bandwidth infrastructure or amplification services rather than a sprawling consumer botnet.

Section 4 | Business Impact

Internal Services Targeted

The 15,500 logged attack events landed against ten internal services. Attack volume concentrated on the highest-criticality components — Core Banking Database and Authentication Service together absorbed over half of all logged events — consistent with an attacker who has performed prior reconnaissance.

Core Banking Database	5	4,705	578	87.7%
Authentication Service	5	4,039	471	88.3%
Customer Portal	4	2,392	274	88.5%
Mobile API Gateway	4	1,489	162	89.1%
Transaction Processing	5	1,396	142	89.8%
Load Balancer	5	448	43	90.4%
Internal DNS	4	372	44	88.2%
Email Service	2	293	29	90.1%
Admin Console	4	221	25	88.7%
Backup Storage	3	145	26	82.1%

Customer-Facing Service Disruption

While the attacks targeted internal infrastructure, the disruption propagated to customer-facing channels. Outage durations below reflect the time between first material degradation and full service restoration.

Online Banking Portal	Complete outage	2 h 24 m	Critical
Mobile Banking App	Degraded (read-only)	1 h 47 m	Critical
Wire Transfer System	Complete outage	2 h 55 m	Critical
ATM Network	Intermittent issues	48 m	High
Business Banking Platform	Complete outage	2 h 10 m	High
Customer Service Portal	Degraded	3 h 05 m	Medium
API Banking Services	Complete outage	3 h 12 m	Medium

Customer & Reputation Impact

Approximately 340,000 customers were unable to access online or mobile banking during the outage window. Roughly 12,400 wire transfers were delayed or required manual handling, and 1,800 business customers in Asia and Europe were unable to process scheduled payments due to the time-zone overlap with the attack window. The customer service team logged 4,200 calls during the incident with average wait times of 45 minutes. Within 24 hours of service restoration, 890 formal complaints were filed and the mobile app store rating fell from 4.2 to 3.1 stars.

Media coverage included 12 articles in regional financial publications and brief mentions on national financial news networks. GTB shares closed 1.8% lower on March 15 with trading volume 180% above average; the share price recovered fully by market close on March 18. No analyst rating changes were issued, though two firms placed cybersecurity on their watch list for the next earnings cycle.

Financial Implications

The directly attributable financial impact totals approximately \$890,000 across six categories. This excludes longer-term effects such as customer attrition, premium increases on cyber insurance, and any costs flowing from regulatory examination findings.

Lost transaction revenue	\$185,000	3-hour peak outage; transaction-fee basis
Incident response costs	\$145,000	Internal overtime, emergency vendor support

Customer compensation	\$78,000	Fee waivers, interest adjustments
Regulatory preparation	\$180,000	Legal, compliance documentation
Infrastructure upgrades	\$245,000	Emergency security enhancements
Reputation / marketing	\$57,000	Customer communications, PR
TOTAL	\$890,000	Direct costs only

Regulatory Exposure

As a federally-regulated financial institution, GlobalTrust must complete several mandatory notifications. A Suspicious Activity Report (SAR) must be filed with FinCEN within 30 days. The OCC must be notified of the significant service disruption, and Federal Reserve incident reports are required as a member bank. State banking regulators in all 12 operating states require parallel notifications.

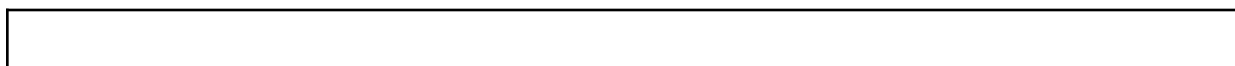
The compliance frameworks implicated by the incident include the Gramm-Leach-Bliley Act safeguards rule, PCI-DSS for payment-card data, Sarbanes-Oxley for financial reporting controls, and various state breach-notification laws. Examiners are likely to focus on the adequacy of the cybersecurity program under FFIEC guidelines, the timeliness and structure of the incident response, and the adequacy of customer notifications.

Section 5 | The Data Available

Four datasets are made available in a relational database (MySQL). Together they support temporal analysis, geographic attribution, threat-actor profiling, and business-impact assessment. The schema and field-level definitions below match the database exactly, so queries written against this specification will run without modification.

Dataset 1: attack_logs

Individual attack events captured by the SIEM and web application firewall. 15,500 records covering the three-hour incident window.



log_id	INT	Primary key, auto-increment
timestamp	DATETIME(3)	UTC time of event (millisecond precision)
source_ip	VARCHAR(15)	Attacker IP address (joins ip_intelligence)
source_port	INT	Attacker source port
destination_ip	VARCHAR(15)	Internal target IP
destination_port	INT	Target port number
protocol	ENUM	TCP / UDP / HTTP / HTTPS
attack_type	ENUM	DDOS_SYN_FLOOD, DDOS_UDP_FLOOD, SQL_INJECTION, BRUTE_FORCE, XSS_ATTEMPT
attack_subtype	VARCHAR(50)	More specific classification (e.g. NTP_AMPLIFICATION)
payload_hash	CHAR(64)	SHA-256 hash of payload
payload_sample	TEXT	Sample of payload (NULL for non-application attacks)
bytes_sent	INT	Bytes in attack payload
packets_count	INT	Packet count for the event
severity	ENUM	LOW / MEDIUM / HIGH / CRITICAL
blocked	BOOLEAN	1 = blocked by control, 0 = passed to application
firewall_rule	VARCHAR(50)	Rule that fired (NULL when not blocked)
target_service_id	INT	Foreign key to affected_services.service_id

Dataset 2: ip_intelligence

Threat-intelligence enrichment for each of the 550 unique attacker IPs, derived from commercial and open-source feeds at the time of the incident.

CONFIDENTIAL Operation Swift Recovery Page 11
Operation Swift Recovery — Cyber Incident Analysis GlobalTrust Bank

ip_address	VARCHAR(15)	Primary key; joins attack_logs.source_ip
country_code	CHAR(2)	ISO country code
country_name	VARCHAR(100)	Country name
city	VARCHAR(100)	Approximate city
latitude / longitude	DECIMAL	Geographic coordinates
isp	VARCHAR(200)	Internet Service Provider

asn	VARCHAR(20)	Autonomous System Number
organization	VARCHAR(200)	Organization that registered the netblock
is_tor	BOOLEAN	Known TOR exit node
is_vpn	BOOLEAN	Known commercial VPN endpoint
is_proxy	BOOLEAN	Known anonymizing proxy
is_hosting	BOOLEAN	Cloud or hosting provider IP space
threat_score	INT	Risk score from threat intel feeds (0–100)
threat_category	ENUM	LOW_CONFIDENCE / SUSPICIOUS / KNOWN_APT_
first_seen / last_seen	DATETIME(3)	Window of malicious activity observed
total_reports	INT	Number of historical abuse reports

Dataset 3: affected_services

The bank's internal service inventory with criticality ratings and recovery objectives. Each row in attack_logs joins here via target_service_id.

service_id	INT	Primary key
service_name	VARCHAR(100)	Human-readable service name
service_type	VARCHAR(50)	DATABASE / API / WEB / SERVICE / INFRASTRUCTURE
ip_address	VARCHAR(15)	Internal IP address
port	INT	Service port
criticality	INT (1–5)	Business criticality (5 = highest)
dependencies	VARCHAR(100)	Comma-separated service IDs this service depends on

owner_team	VARCHAR(100)	Team responsible
recovery_time_objective	INT	RTO in minutes

status	ENUM	ONLINE / OFFLINE / DEGRADED
--------	------	-----------------------------

Dataset 4: incident_timeline

21 events documenting the SOC and incident response team's chronological actions and observations during the campaign.

event_id	INT	Primary key, auto-increment
timestamp	DATETIME(3)	UTC time of event
event_type	ENUM	DETECTION / ALERT / ESCALATION / ANALYSIS / MITIGATION / CONTAINMENT / RECOVERY / CLOSURE / BREACH
description	TEXT	Detailed event description
severity	ENUM	LOW / MEDIUM / HIGH / CRITICAL
reported_by	VARCHAR(100)	Person, system, or team that reported
action_taken	TEXT	Action taken in response

Joining the Datasets

attack_logs.source_ip → **ip_intelligence.ip_address** enriches each attack event with geographic, ISP, anonymization, and threat-intelligence context.

attack_logs.target_service_id → **affected_services.service_id** attaches business context (criticality, RTO, owner team) to each attack event.

Timestamps across all four tables are UTC and millisecond-precise, enabling temporal correlation of attacker behavior with response actions.

Section 6 | Stakeholder Requirements

Different parts of the organization need different things from the same incident data. The same finding — that 24% of SQL injection attempts reached the application layer — becomes a board-level investment decision for the CEO, a control-effectiveness metric for the CISO, evidence of due diligence for the legal team, and a

patch-priority signal for IT operations. Strong analysis anticipates the four perspectives below and produces outputs calibrated to each.

Chief Information Security Officer (CISO)

Accountable for the bank's overall security posture and reporting to the Board on incident details, response effectiveness, and security program improvements.

Attack source identification	Critical	Comprehensive list of attacking IPs with confidence levels and attribution analysis
Threat actor profiling	Critical	Sophistication assessment, likely motivation, possible state involvement
Attack vector breakdown	High	Volumes, success rates, and observed techniques per vector
Defense effectiveness	High	Which controls held, which failed, where the gaps sit
Recommendations	Critical	Prioritized improvements with rough cost-benefit analysis
Blocking criteria	High	Defensible, documentable rules for permanent IP blocking

Chief Executive Officer (CEO)

Communicates with shareholders, regulators, and the public; makes resource and risk-acceptance decisions. Needs jargon-free, decision-ready synthesis.

Executive summary	Critical	One-page overview suitable for Board presentation and external communication
Damage assessment	Critical	Customer impact, financial losses, operational disruption — quantified
Recovery timeline	High	Visual timeline of service restoration with confidence intervals
Forward-looking risk	Critical	Residual risk assessment and likelihood of repeat attack
Peer comparison	Medium	How this incident compares to other financial-services incidents
Investment needs	High	Budget implications of recommended improvements at a high level

Legal & Compliance Team

Prepares regulatory filings, anticipates litigation, ensures notification obligations are met. Requires defensible, well-documented evidence with clear chain of custody.

--	--	--

Evidence documentation	Critical	Chain-of-custody documentation for forensic evidence
Timeline accuracy	Critical	Precise, validated timestamps for every significant event
Regulatory data	Critical	Pre-formatted data for SAR, OCC notification, state breach notices
Audit trail	High	Complete log of response actions, decisions, and rationale
Exposure analysis	Critical	Definitive assessment of whether customer PII was accessed
Third-party assessment	Medium	Summary of external IR firm findings for regulatory submission

IT Operations

Restores services, implements emergency changes, maintains ongoing monitoring. Needs actionable technical guidance with clear sequencing.

Service priority matrix	Critical	Ordered restoration list with dependencies mapped
Safety assessment	Critical	Which systems are confirmed safe vs. require additional scanning
Monitoring requirements	High	Indicators of compromise to monitor post-recovery
Firewall rules	Critical	Specific IP ranges and rules to implement immediately
Capacity planning	Medium	Traffic patterns to inform infrastructure scaling
Patch priority	High	Vulnerabilities exploited and patches required, in priority order

Section 7 | Analysis Questions

The questions below are organized into five parts that progress from understanding the attack to producing executive deliverables. Support every conclusion with specific evidence drawn from the datasets. Where assumptions are necessary, state them explicitly. Where uncertainty is irreducible, acknowledge it and quantify confidence.

Part A: Understanding the Attack

Q1. What patterns in the data indicate this was a coordinated attack rather than random, opportunistic scanning?

Examine launch timing across attack types, geographic and infrastructure clustering, and per-IP behavior across vectors. Reference specific data points (timestamps, IP counts, country distributions) rather than generic claims. Distinguish between evidence that is consistent with coordination and evidence that demands it.

Q2. Which attack type was most frequent? Which was most dangerous? Are these the same?

Frequency and danger are not the same metric. Build a frequency view from event counts and a danger view that weights by potential consequence (data exfiltration risk, credential compromise risk, service disruption). Show the rankings side by side and explain why a responder should not allocate attention by frequency alone.

Q3. What time was the peak attack intensity? Why does the timing matter from a business and security perspective?

Find the peak at minute and 15-minute granularity. Convert to local time at headquarters (Chicago, Central). Discuss what the timing implies about attacker intent, knowledge of the bank's operations, and the resilience of overnight defensive capacity.

Part B: Geographic Attribution**Q4. Which countries originated the most attack traffic?**

Present both raw attack volume and unique-IP counts by country. Discuss the limitations of geographic attribution from IP addresses alone — geolocation is approximate, IPs can be hosted infrastructure rather than the attacker's actual location, and anonymization services can mask origin entirely.

Q5. What percentage of attacking IPs used anonymization services? What does this indicate about attacker sophistication?

Compute anonymization rates correctly: an IP can be flagged as multiple types (TOR + proxy, for example), so subtracting individual counts from the total will produce an incorrect 'direct' figure. Compute the union of TOR / VPN / proxy flags. Compare anonymization rates across attack types and discuss what differences imply about the attacker's tradecraft.

Q6. Based on the available evidence, can you identify potential indicators of state-sponsored activity?

Build an explicit checklist of indicators (geographic concentration, APT-flagged infrastructure, sophistication of techniques, timing, targeting precision). Score each indicator against the data. Be explicit about confidence levels, what the data cannot tell you, and what would be required to raise the confidence level.

Part C: Threat Actor Analysis**Q7. Identify the top 10 most dangerous IP addresses. Document and justify your ranking methodology.**

Develop a composite scoring framework that incorporates attack volume, success rate, severity profile, threat-intelligence reputation, and anonymization usage. State your weights and the rationale for each. Discuss how the framework's behavior would change under different weight choices — sensitivity analysis is part of a defensible methodology.

Q8. Are there identifiable patterns in attacker behavior? Do these patterns suggest multiple threat actors or a single coordinated campaign?

Cluster attackers by behavioral features (duration, intensity, vector breadth, target diversity). Examine whether observed patterns are best explained by one campaign with specialized roles or by multiple independent actors. Consider what evidence would change your conclusion.

Q9. Which Internet Service Providers were most associated with attack traffic? What action should GlobalTrust take?

Identify the top ISPs by attack volume and unique-IP count. Discuss the tradeoff in ISP-level blocking: it is operationally simple but coarse, and may block legitimate customers. Recommend a tiered response (block, rate-limit, monitor) with explicit criteria.

Part D: Business Recommendations

Q10. Create a service restoration priority matrix.

Restoration priority should weigh business criticality, dependency relationships, and incremental risk from successful attacks already observed. A higher-criticality service with confirmed successful attacks may warrant more pre-restoration verification, not less. Justify your prioritization framework.

Q11. Which IP addresses should be permanently blocked? Define defensible criteria. State your blocking criteria explicitly, then apply them to the dataset. Balance security benefit against the cost of over-blocking (legitimate customers behind shared infrastructure, false positives from anonymization service users). Make the criteria reviewable and auditable — every block should have a documentable trigger.

Q12. What security improvements would you recommend?

Prioritize by impact and feasibility. For each recommendation, state the gap in this incident's data that justifies it, an approximate cost range, an implementation timeframe, and the expected reduction in residual risk. Address both technical controls and process improvements (SOC staffing, runbook quality, threat-intelligence integration).

Part E: Deliverables

Q13. Create an executive dashboard.

Suitable for a Board of Directors presentation. Include attack timeline, geographic distribution, service impact, and key metrics. Prioritize clarity over completeness.

Q14. Write a one-page executive summary for the CEO.

This document will be shared with the Board and may be shared with regulators. Accuracy and clarity matter more than thoroughness. Lead with what happened and what was contained; follow with impact, response effectiveness, and the path forward. Avoid technical jargon.

Q15. Prepare a technical report for the CISO.

CONFIDENTIAL Operation Swift Recovery Page 17
Operation Swift Recovery — Cyber Incident Analysis GlobalTrust Bank

This report should include detailed threat-actor analysis, vector breakdown, defense effectiveness assessment, indicators of compromise, and prioritized technical recommendations. Show your methodology and acknowledge limitations.

Section 8 | Evaluation Criteria

Work is evaluated not only on technical accuracy but on the business value and actionability of the analysis. Strong submissions translate findings into decisions, anticipate stakeholder needs, and acknowledge what the data cannot say.

--

Business understanding	25%	Consistently translates findings into business impact; anticipates stakeholder needs
Quality of insights	25%	Discovers non-obvious patterns; insights are specific and well-supported by evidence
Communication	20%	Clear, professional presentation; appropriate detail for each audience; effective visualizations
Recommendations	20%	Specific, prioritized, feasible; includes implementation considerations and tradeoffs
Methodology	10%	Transparent and reproducible; appropriate techniques; explicit about limitations

Common Pitfalls

Technical tunnel vision. Focusing on data manipulation without connecting findings to business outcomes.

Unsupported conclusions. Making claims without citing specific data points or acknowledging uncertainty.

Audience mismatch. Presenting technical detail to executives or oversimplifying for technical audiences.

Recommendation overload. Listing many recommendations without prioritization or feasibility assessment.

Visualization noise. Charts that obscure rather than illuminate. Three good charts beat ten cluttered ones.

Mechanical errors in attribution. Adding TOR, VPN, and proxy counts to compute 'direct' attacks without de-duplicating IPs flagged as multiple types. Always work with set unions rather than sums for boolean flags.

Section 9 | Background Reading

Banking Cybersecurity Landscape

CONFIDENTIAL Operation Swift Recovery Page 18
Operation Swift Recovery — Cyber Incident Analysis GlobalTrust Bank

Financial institutions are among the most targeted sectors for cyber attacks. Three factors drive this: direct monetary value of successful breaches, vast stores of personally identifiable information, and complex legacy systems with non-trivial attack surfaces. Industry studies report that financial services experience roughly 300 times the attack volume of other sectors, and that the average cost of a financial-services data breach exceeds \$5.9 million.

Common Attack Vectors in Financial Services

Phishing / social engineering	Very high	Credential theft, malware delivery
Web application attacks	High	Data theft, service disruption
DDoS attacks	High	Service availability, reputation

Ransomware	Medium-high	Operational disruption, data loss
Insider threats	Medium	Data theft, fraud
Supply chain attacks	Medium	Broad access, persistent presence
ATM / POS malware	Medium	Direct financial theft

Incident Response Frameworks

NIST Cybersecurity Framework. Organizes security activities into Identify, Protect, Detect, Respond, and Recover. This case primarily exercises Detect, Respond, and Recover.

FFIEC Guidance. The Federal Financial Institutions Examination Council provides cybersecurity guidance specific to financial institutions, including incident response plan requirements, business continuity, and regulatory reporting.

MITRE ATT&CK. A knowledge base of adversary tactics and techniques based on real-world observations. Useful for classifying attacker behavior in this case.

Incident Response Lifecycle. Standard incident response follows phases of Preparation, Detection & Analysis, Containment, Eradication & Recovery, and Post-Incident Activity. The data provided spans Detection through Recovery.

Section 10 | Glossary

APT (Advanced Persistent Threat)	A sophisticated, often state-sponsored threat actor that maintains long-term access to target environments. Threat-intel feeds tag IPs as APT_SUSPECTED based on infrastructure overlap with known APT operations.
ASN (Autonomous System Number)	A unique identifier for a collection of IP networks under a single administrative entity, such as an ISP.
Botnet	A network of compromised devices controlled by an attacker, often used to launch DDoS or credential-stuffing attacks.

Brute Force	An attack that systematically tries password combinations or uses leaked credential lists to gain unauthorized access.
CDN (Content Delivery Network)	A distributed network of servers that caches and delivers web content, often providing DDoS mitigation as a side effect.
Credential Stuffing	A brute-force variant that uses credentials from third-party breaches against the target system, exploiting password reuse.
DDoS (Distributed Denial of Service)	An attack that overwhelms a target with traffic from many sources, exhausting bandwidth, connection state, or compute resources.
FFIEC	Federal Financial Institutions Examination Council — interagency body that prescribes uniform principles for financial-institution examination.
FinCEN	Financial Crimes Enforcement Network — bureau of the U.S. Treasury that collects and analyzes financial transaction data.
GLBA	Gramm-Leach-Bliley Act — federal law requiring financial institutions to protect consumer financial information.
HTTP Flood	A DDoS variant that overwhelms web servers with seemingly legitimate HTTP requests.
IOC (Indicator of Compromise)	Forensic artifacts that indicate a potential security breach (malicious IP addresses, file hashes, domain names).
IR (Incident Response)	The organized approach to addressing and managing a security breach.
ISP (Internet Service Provider)	A company that provides internet connectivity, routing customer traffic through its network.
NIST	National Institute of Standards and Technology — develops cybersecurity standards and frameworks.

OCC	Office of the Comptroller of the Currency — federal agency that charters, regulates, and supervises national banks.
PCI-DSS	Payment Card Industry Data Security Standard — security standards for organizations handling card data.
PII (Personally Identifiable Information)	Information that identifies a specific individual (name, SSN, account number).
RTO (Recovery Time Objective)	The maximum acceptable time a service can be offline after a disruption.
SAR (Suspicious Activity Report)	A report financial institutions file with FinCEN for suspicious transactions or activity.

SIEM	Security Information and Event Management — technology that aggregates and analyzes security event data.
SOC (Security Operations Center)	A facility where security analysts monitor, detect, and respond to incidents.
SOX	Sarbanes-Oxley Act — federal law establishing auditing and financial regulations for public companies.
SQL Injection	An attack that inserts malicious SQL into application queries to manipulate or extract data from the database.
SYN Flood	A DDoS variant that abuses the TCP handshake by sending many SYN requests without completing the connection.
TOR (The Onion Router)	An anonymity network that routes traffic through encrypted layers to conceal user identity.
UDP Flood	A DDoS variant that overwhelms a target with UDP packets, often using amplification.
VPN (Virtual Private Network)	Technology that creates encrypted connections, often used to anonymize traffic origin.
WAF (Web Application Firewall)	A security solution that filters and monitors HTTP traffic to protect web applications.
XSS (Cross-Site Scripting)	An attack that injects malicious scripts into web pages viewed by other users.